Introduction à la cybersécurité

Fiche méthode

Raisonnements pour les QCM · Chapitres 1 à 5

1. Lire le QCM par propriété

Repère l'objet demandé : le système, le message, l'identité, la clé, le canal ou le nom de domaine. Identifie ensuite l'opération et l'attaquant. Évalue chaque proposition séparément. « Empêche », « toujours » et « garantit » exigent une preuve plus forte que « réduit ». Un mot familier dans une proposition ne suffit pas.

Exemple. Un attaquant rejoue une requête valide qu'il a enregistrée. Le message peut rester intact et sa signature valide. C'est sa fraîcheur qui manque : il faut lier la preuve à un défi unique ou à une séquence dont le destinataire vérifie l'usage.

2. Objectifs, menaces et contrôles

Propriété	Question à poser
Confidentialité	Qui peut lire l'information ?
Intégrité	Une altération non autorisée est-elle détectée ?
Disponibilité	Le service reste-t-il utilisable quand on en a besoin ?
Authenticité	La provenance ou l'identité revendiquée est-elle vérifiée ?
Responsabilité	Peut-on rattacher une action à un acteur et l'auditer ?
Non-répudiation	Dispose-t-on d'éléments de preuve opposables, au-delà d'un simple journal ?

Une saturation distribuée vise la disponibilité. Le phishing exploite la confiance pour obtenir une action ou un secret ; l'attaque ne suppose pas que le chiffrement ait été cassé. L'authentification vérifie une identité ; l'autorisation décide de l'accès ; la journalisation rend l'action retraçable. Privilège minimal et séparation des fonctions limitent le pouvoir d'un seul rôle.

3. Choisir le bon outil cryptographique

— **Chiffrement** : réserve la lecture aux détenteurs de la clé appropriée. Une forme de chiffrement sans authentification n'assure pas automatiquement l'intégrité. Les modes authentifiés protègent aussi contre les altérations.
— **Hachage** : produit une empreinte. Une empreinte non authentifiée ne protège pas seule contre un attaquant capable de remplacer le fichier *et* l'empreinte.
— **MAC** : authentifie un message avec un secret partagé. Les détenteurs du même secret peuvent tous fabriquer le code ; ce n'est pas une preuve publique de l'identité du signataire.
— **Signature** : la clé privée signe et la clé publique vérifie. Elle peut prouver l'intégrité et l'origine si la clé de vérification est liée à la bonne identité. Elle ne chiffre pas le contenu.

Une collision existe nécessairement quand l'ensemble des messages possibles dépasse l'ensemble des empreintes. La sécurité demande qu'en trouver une soit impraticable. Ne pas confondre collision (deux entrées libres), seconde préimage (une entrée fixée) et préimage (une empreinte fixée). L'effet d'avalanche concerne la diffusion des changements ; il ne démontre pas à lui seul la résistance aux collisions.

Un chiffrement par blocs traite des blocs de taille fixe ; le mode définit le traitement de plusieurs

blocs et son besoin éventuel de remplissage. Une KDF dérive du matériel de clé, par exemple des clés séparées d'un secret partagé. Pour un mot de passe, utiliser une dérivation adaptée aux secrets faibles et un sel propre à chaque stockage, pas un simple hachage rapide.

Test mental. Selon Kerckhoffs, le système doit rester sûr si sa conception est connue. Le secret à protéger est la clé ; cacher le code ou l'algorithme ne remplace pas cette protection.

Le chiffrement de César a peu de clés et conserve les fréquences des lettres à un décalage près. Dans Merkle–Damgård, on part d'une valeur initiale fixée et l'on applique une compression bloc après bloc, en utilisant l'état obtenu au bloc précédent.

4. Échanger une clé et établir la confiance

Avec Diffie–Hellman, chacun garde son exposant secret, échange sa valeur publique et calcule le même secret de son côté. Sans authentification des messages, un intermédiaire actif peut établir deux secrets distincts. Dans un transport de clé RSA, le destinataire déchiffre avec sa clé privée une valeur chiffrée à sa clé publique ; ne pas confondre ce sens avec celui de la signature.

Un certificat X.509 associe une identité à une clé publique. Distingue le sujet, l'émetteur, la période de validité, le numéro de série et la signature de l'émetteur. La clé privée du sujet ne figure pas dans le certificat. Pour valider une chaîne, remonter les signatures jusqu'à une ancre de confiance déjà reconnue ; vérifier aussi le nom, la date et les contraintes applicables. Un certificat peut être révoqué avant son expiration ; une liste de révocation ou une vérification du statut sert à le constater. Une racine n'est pas digne de confiance du seul fait qu'elle est auto-signée.

Exemple. Un certificat valide pour `service-a.example` ne prouve pas l'identité de `service-b.example`. Une erreur de nom, une expiration et une signature invalide sont trois diagnostics distincts.

5. Authentification et accès

Facteurs. Connaissance : un mot de passe ; possession : une clé matérielle ; inhérence : une caractéristique biométrique. Deux secrets mémorisés ne font pas deux facteurs différents. Un OTP accepté une fois limite le rejeu, sans empêcher qu'un fraudeur le relaie en temps réel. Pour un défi signé, vérifier la signature, le lien au contexte et la fraîcheur du défi.

Mots de passe. À la vérification, recalculer la dérivation avec le sel et les paramètres enregistrés, puis comparer au résultat stocké. Le sel ne doit pas être secret ; il évite notamment de partager une même empreinte entre des comptes ayant le même mot de passe. Transmettre le mot de passe via TLS ; un hachage fixe envoyé à sa place peut devenir un secret réutilisable. Préférer une phrase longue et unique, conservée dans un gestionnaire, et la changer en cas de compromission.

OTP. Un OTP peut évoluer avec un compteur ou le temps. Chez Lamport, on remonte une chaîne de hachages : le serveur applique une fois le hachage à la valeur reçue et la compare à la dernière valeur conservée.

Protocoles. Une preuve à divulgation nulle démontre la connaissance sans livrer le secret. WebAuthn utilise une paire de clés liée au service et signe un défi ; la clé privée ne part pas au serveur. OAuth organise la délégation d'autorisation ; OpenID Connect y ajoute une couche d'identité. Un JWT est un format de jeton : un JWT signé n'est pas forcément chiffré. Vérifier la signature, l'émetteur, le destinataire et l'expiration selon le contexte.

6. Réseau : identifier où s'arrête la protection

Chapitre 5 préparé ; sa présence à l'examen reste à confirmer.

— **TLS** : un canal protégé entre deux points TLS. En usage web, le serveur s'authentifie typiquement

par certificat ; authentifier également le client demande un mécanisme prévu. Les données applicatives bénéficient de confidentialité et d'intégrité, mais le trafic n'est ni anonyme ni exempt de métadonnées visibles. Le canal ordinaire protège ses enregistrements du rejeu ; les données précoces 0-RTT de TLS 1.3 demandent une vigilance particulière.
— **VPN** : le tunnel protège jusqu'à sa terminaison. Un serveur VPN peut relayer un trafic qui n'est plus protégé par ce tunnel. Le chiffrement de bout en bout place au contraire les terminaisons cryptographiques chez les correspondants finaux.
— **Pare-feu et segmentation** : appliquer une politique aux flux, isoler les zones et restreindre les accès entre elles. Une DMZ héberge typiquement des services exposés, séparés du réseau interne. Un WAF examine du trafic web à la couche applicative.
— **802.1X** : distinguer le demandeur, l'équipement qui contrôle le port et le serveur qui vérifie l'accès. Le protocole contrôle l'admission ; il n'est pas en lui-même un chiffrement général des flux applicatifs. EAPOL circule sur le lien local, et l'équipement relaie souvent les échanges vers le serveur via RADIUS.
— **DNSSEC** : vérifie l'origine et l'intégrité des données DNS signées et permet une preuve authentifiée de certaines absences. Il ne chiffre pas les requêtes et ne valide pas à lui seul le contenu du site web. Le cours appelle aussi « non-répudiation » le lien à la zone signataire ; retiens la garantie d'authenticité de l'origine. Le parent délègue la confiance au moyen d'un enregistrement DS correspondant à une clé de la zone enfant.

7. Réviser à partir des annales

Commence par une épreuve en répondant avant d'ouvrir le corrigé. Pour chaque erreur, note en une ligne la confusion : objectif, condition, clé, portée du canal ou acteur. Reprends ensuite les cartes du chapitre correspondant, puis résous une question voisine sans chercher à mémoriser sa lettre. Pour une question dont le corrigé signale une ambiguïté, apprends la distinction technique et le contexte qui font varier la réponse.

Sources de travail : cours ESI, chapitres 1 à 5 et cinq annales ; les corrigés donnent les références question par question.